

PLANO DE TESTES EXECUTADO

Sistema de Gestão de Produtos - Segurança, Controle de Acesso e Interface

Objetivo

Validar os principais requisitos funcionais, de segurança e de interface da aplicação web, incluindo autenticação, armazenamento seguro de senhas, autorização por perfil, proteção de operações, validação de entradas, resistência a tentativa de injeção de SQL e responsividade.

Ambiente de teste

Aplicação web executada localmente em localhost:3000, com Node.js/Express no servidor, arquitetura MVC/DAO, banco de dados MySQL e navegador Google Chrome. Foram utilizados os perfis Administrador (admin) e Usuário Comum (usuario).

Resumo dos casos de teste

ID	Caso de teste	Resultado
CT01	Senha protegida por hash BCrypt no banco	PASSOU
CT02	Login com credenciais inválidas	PASSOU
CT03	Login e permissões do Usuário Comum	PASSOU
CT04	Consulta de produtos pela API	PASSOU
CT05	Permissões do Administrador	PASSOU
CT06	Bloqueio de operação administrativa para usuário comum	PASSOU
CT07	Exibição da logo do cliente parceiro	PASSOU
CT08	Validação de entrada inválida (preço negativo)	PASSOU
CT09	Tentativa de SQL Injection tratada como dado	PASSOU*
CT10	Responsividade em viewport 390 x 844 px	PASSOU

* No teste CT09, a evidência mostra que a string maliciosa não foi executada como comando SQL: ela foi inserida como conteúdo textual. Isso é compatível com uso de consulta parametrizada/prepared statement, embora a aplicação também deva validar e rejeitar entradas inadequadas conforme a regra de negócio.

CT01 - Armazenamento seguro de senha

Result Grid

Filter Rows

1

2

1

2

id

nome

email

perfil

senha_hash

1

Administrador

admin@teste.com

admin

\$2a\$12\$PwEls.nHfalsQHTSP4JUKg2WHL...

2

Usuario Comum

usuario@teste.com

usuario

\$2a\$12\$ouEBqutSxvHtnz2Z7gDehEp6YFCD...

Result Grid

Form Editor

Field Types

Query Status

Execution Plan

Result: 2

usuario 3

Output

Apply

Content Help

Snippets

Action Output

#

Time

Action

Message

Duration / Fech

11

15:15:56

CREATE TABLE IF NOT EXISTS produto (id INT AUTO_INCREMENT PRIMARY KEY, nome VARCHAR(100) NOT NULL, categoria VARCHAR(50) NOT NULL, preco DECIMAL(10,2) NOT NULL, quantidade INT NOT NULL)

0 row(s) affected, 1 warning(s): 1050 Table 'produto' already exists

0.000 sec

12

15:15:56

INSERT INTO produto (nome, categoria, preco, quantidade) SELECT 'Teclado Mecânico', 'Periféricos', 249.90, 10 WHERE NOT EXISTS (SELECT 1 FROM produto WHERE nome = 'Teclado Mecânico')

0 row(s) affected Records: 0 Duplicates: 0 Warnings: 0

0.000 sec

13

15:15:56

INSERT INTO produto (nome, categoria, preco, quantidade) SELECT 'Mouse Sem Fio', 'Periféricos', 89.90, 25 WHERE NOT EXISTS (SELECT 1 FROM produto WHERE nome = 'Mouse Sem Fio')

0 row(s) affected Records: 0 Duplicates: 0 Warnings: 0

0.000 sec

14

15:15:56

DESCRIBE usuario

7 row(s) returned

0.000 sec / 0.000 sec

15

15:15:56

USE sistema_produtos

0 row(s) affected

0.000 sec

16

15:15:56

SELECT id, nome, email, perfil, senha_hash FROM usuario LIMIT 0, 1000

2 row(s) returned

0.000 sec / 0.000 sec

Ativar o Windows

Acesse Configurações para ativar o Windows

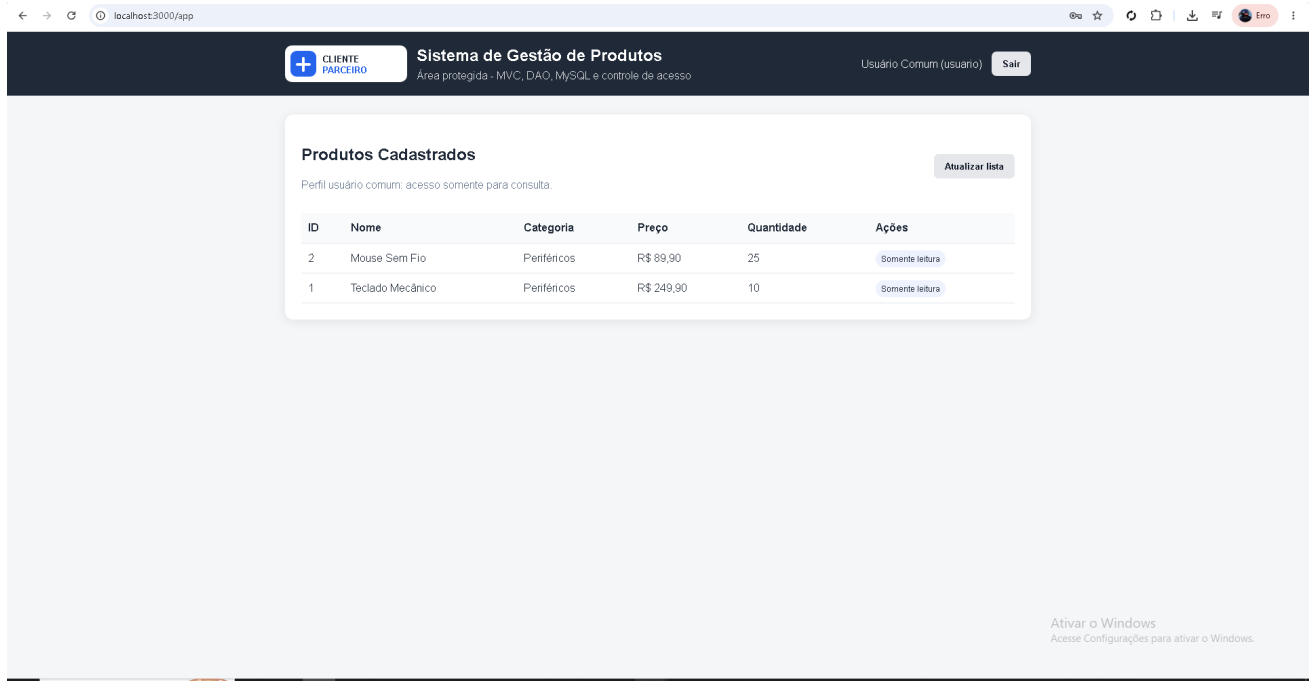
CT02 - Login inválido

A screenshot of a web browser window. The address bar shows 'localhost:3000/login'. The page has a light blue background. In the center is a white login card. The card has a blue header with a plus icon and the text 'CLIENTE PARCEIRO'. Below this is the title 'Acesso ao Sistema'. A subtitle says 'Entre com suas credenciais.' There are two input fields: 'E-mail' with the value 'admin@teste.com' and 'Senha' with masked characters. A blue 'Entrar' button is below the fields. At the bottom of the card, red text says 'E-mail ou senha inválidos.' In the bottom right corner of the browser window, there is a Windows activation watermark: 'Ativar o Windows. Acesse Configurações para ativar o Windows.'

Plano de Testes - Sistema de Gestão de Produtos | Página 2

CT03 - Perfil Usuário Comum

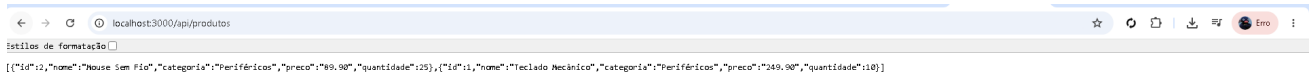
Objetivo	Verificar autorização de leitura para o perfil usuario.
Procedimento	Autenticar como Usuário Comum e acessar a aplicação.
Resultado obtido	A listagem é exibida em modo somente leitura, sem cadastro, edição ou exclusão.
Status	PASSOU



Evidência 3 - Perfil Usuário Comum autenticado com acesso somente para consulta.

CT04 - Consulta da API

Objetivo	Verificar a leitura dos produtos cadastrados.
Procedimento	Acessar a rota GET /api/produtos.
Resultado obtido	A API retorna os produtos em JSON.
Status	PASSOU



Evidência 4 - Consulta GET da API de produtos retornando os registros cadastrados.

CT05 - Perfil Administrador

Objetivo	Verificar permissões administrativas.
Procedimento	Autenticar como Administrador e acessar a aplicação.
Resultado obtido	São exibidos formulário de cadastro e ações Editar/Excluir.
Status	PASSOU

← → ↻ localhost:3000/app

+

CLIENTE PARCEIRO

Sistema de Gestão de Produtos

Área protegida - MVC, DAO, MySQL e controle de acesso

Administrador (admin)Sair

Cadastrar Produto

Nome

Categoria

Preço

Quantidade

Cadastrar

Produtos Cadastrados

Atualizar lista

Perfil administrador: leitura, cadastro, edição e exclusão.

ID	Nome	Categoria	Preço	Quantidade	Ações
2	Mouse Sem Fio	Periféricos	R\$ 89,90	25	Editar Excluir
1	Teclado Mecânico	Periféricos	R\$ 249,90	10	Editar Excluir

Ativar o Windows
Acesse Configurações para ativar o Windows.

Evidência 5 - Perfil Administrador com acesso às operações de cadastro, edição e exclusão.

CT06 - Acesso não autorizado

Objetivo	Garantir que esconder botões no front-end não seja a única proteção.
Procedimento	Como Usuário Comum, enviar POST diretamente para /api/produtos.
Resultado obtido	O servidor retorna HTTP 403 Forbidden e informa que o acesso é permitido apenas para administradores.
Status	PASSOU

← → ↻ localhost:3000/app

+

CLIENTE PARCEIRO

Sistema de Gestão de Produtos

Área protegida - MVC, DAO, MySQL e controle de acesso

Usuário Comum (usuario)Sair

Produtos Cadastrados

Atualizar lista

Perfil usuário comum: acesso somente para consulta.

ID	Nome	Categoria	Preço	Quantidade	Ações
2	Mouse Sem Fio	Periféricos	R\$ 89,90	25	Somente leitura
1	Teclado Mecânico	Periféricos	R\$ 249,90	10	Somente leitura

DevTools is now available in Portuguese

Don't show againAlways match Chrome's language

Switch DevTools to Portuguese

Warning: Don't paste code into the DevTools Console that you don't understand or haven't reviewed yourself. This could allow attackers to steal your identity or take control of your computer. Type "allow pasting" below and press Enter to allow pasting.

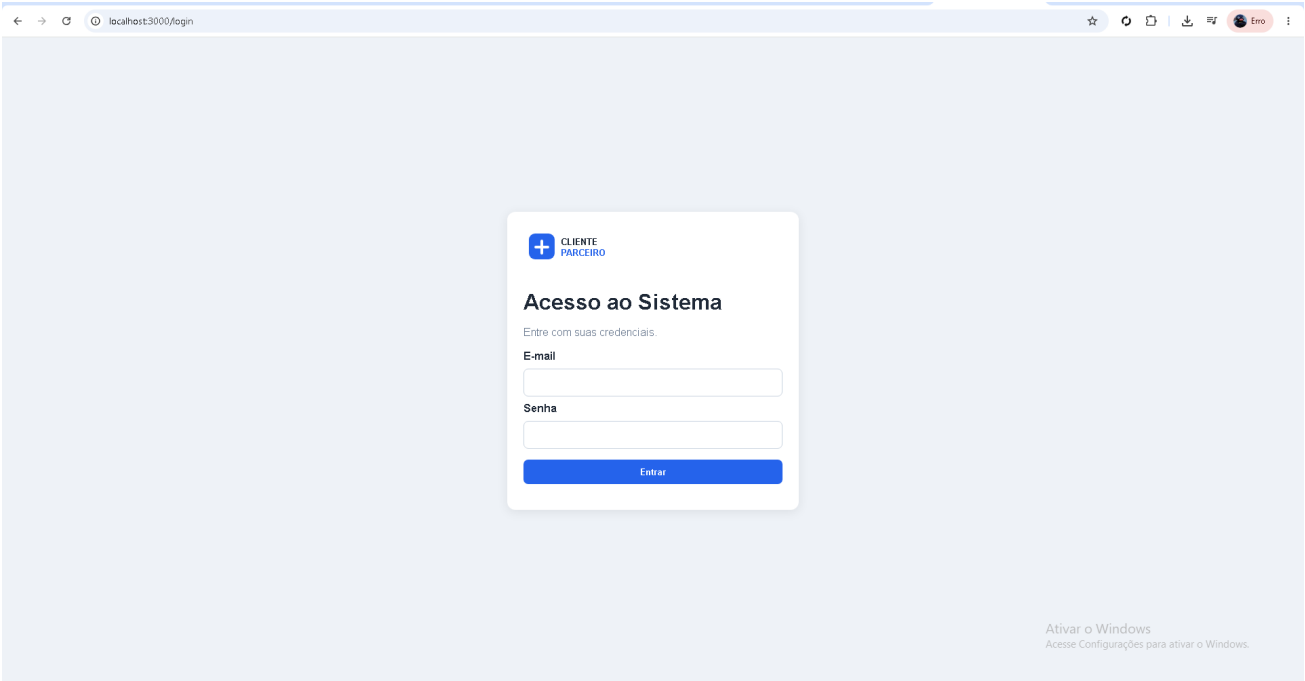
allow pasting

> fetch('/api/produtos', {
 method: 'POST',
 headers: {
 'Content-Type': 'application/json'
 }
},
 body: JSON.stringify({
 nome: 'Produto Teste',
 categoria: 'Teste',
 preco: 10,
 quantidade: 1
 })
})
).then(async resposta => {
 console.log('STATUS:', resposta.status);
 console.log('RESPOSTA:', await resposta.text());
});
< * POST http://localhost:3000/api/produtos 403 (Forbidden) 1075s11
STATUS: 403 1075s114
RESPOSTA: {"erro":"Acesso permitido apenas para administradores."} 1075s115
>|

Evidência 6 - Tentativa de POST pelo Usuário Comum bloqueada com HTTP 403 Forbidden.

CT07 - Logo do cliente

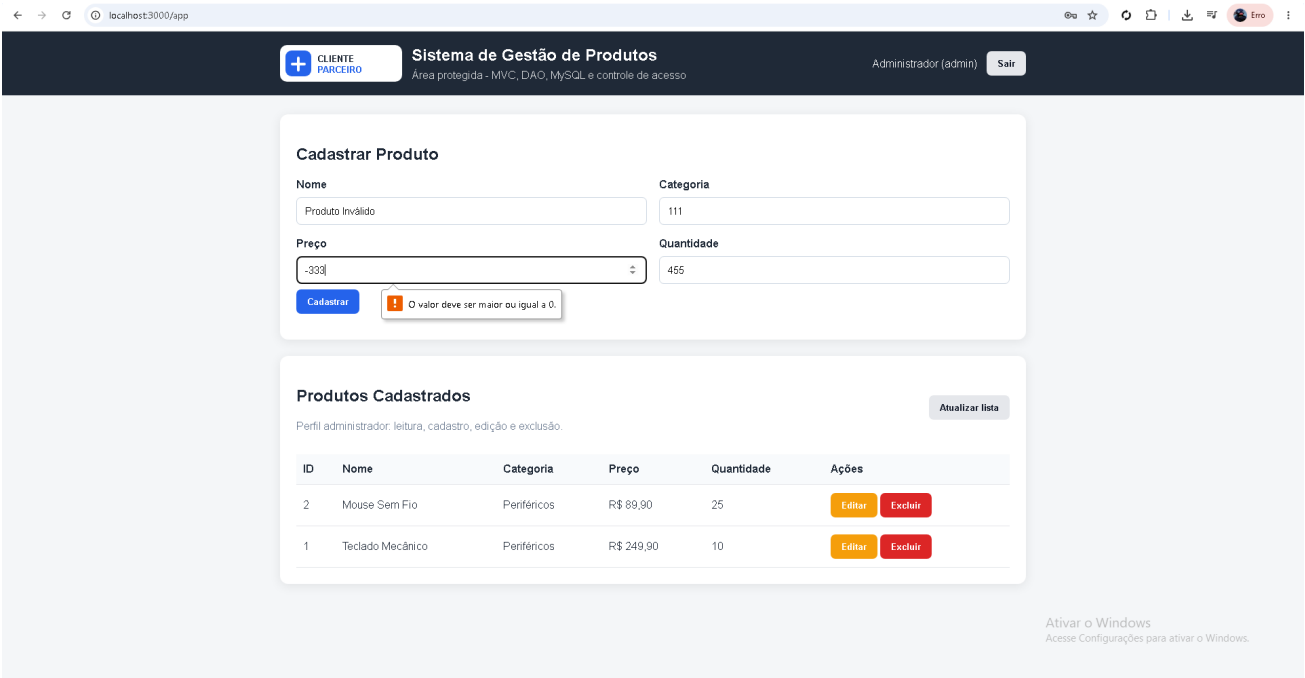
Objetivo	Verificar a presença da identidade do cliente nas páginas.
Procedimento	Abrir a tela de login/aplicação.
Resultado obtido	A logo CLIENTE PARCEIRO é exibida na interface.
Status	PASSOU



Evidência 7 - Tela de login com logo do cliente parceiro.

CT08 - Entrada inválida

Objetivo	Impedir cadastro com valor de preço negativo.
Procedimento	Informar preço -335 no formulário.
Resultado obtido	O navegador impede o envio e informa que o valor deve ser maior ou igual a 0.
Status	PASSOU



Evidência 8 - Validação de preço negativo impedindo o envio de dado inválido.

CT09 - Tentativa de SQL Injection

Objetivo	Verificar se uma entrada com sintaxe SQL é executada pelo banco.
Procedimento	Enviar no campo nome uma string contendo tentativa de DROP TABLE.
Resultado obtido	A requisição retorna 201 e o conteúdo aparece como texto na tabela; a tabela produto continua existente. A injeção não foi executada.
Status	PASSOU*

Result Grid

Filter Rows

id nome categoria preço quantidade

1 Teclado Mecânico Periféricos 249.90 10

2 Mouse Sem Fio Periféricos 89.90 25

6 ; DROP TABLE produtos; -- Teste 10.00 1

Export/Import

Wrap Cell Contents

Result Grid

Form Editor

Field Types

Query Stats

Execution Plan

Result 4

usuario 5

Result 6

produto 7

Output

Apply

Context Help

Snippets

Action Output

#	Time	Action	Message	Duration / Fetch
23	15:25:12	DESCRIBE usuario	7 row(s) returned	0.000 sec / 0.000 sec
24	15:25:12	USE sistema_produtos	0 row(s) affected	0.000 sec
25	15:25:12	SELECT id, nome, email, perfil, senha_hash FROM usuario LIMIT 0, 1000	2 row(s) returned	0.000 sec / 0.000 sec
26	15:25:12	USE sistema_produtos	0 row(s) affected	0.000 sec
27	15:25:12	SHOW TABLES	3 row(s) returned	0.000 sec / 0.000 sec
28	15:25:12	SELECT * FROM produto LIMIT 0, 1000	3 row(s) returned	0.000 sec / 0.000 sec

Evidência 9 - Teste de entrada semelhante a SQL Injection armazenada como texto, sem execução do comando.

CT10 - Responsividade

Objetivo	Verificar adaptação da interface a dispositivos móveis.
Procedimento	Usar o modo responsivo do Chrome em 390 x 844 px.
Resultado obtido	Cabeçalho e formulário são reorganizados para uma coluna, mantendo controles utilizáveis e conteúdo legível.
Status	PASSOU

localhost:3000/app Dimensions: Responsive x 390 x 844 Fit to window No throttling "Save-Data" default CLIENTE PARCEIRO Sistema de Gestão de Produtos Área protegida - MVC, DAO, MySQL e controle de acesso Administrador (admin) Sair Cadastrar Produto Nome Categoria Preço Quantidade Cadastrar	
DevTools is now available in Portuguese Don't show again Always match Chrome's language Switch DevTools to Portuguese Elements Console Sources Network STATUS: 201 RESPOSTA: {"id":6,"nome":": DROP TABLE produtos; --", "categoria":"Teste", "preço":"10.00", "quantidade":1} Console What's new X AI assistance New in DevTools (September 2026) See all new features Ativar o Windows DevTools for agents	

Evidência 10 - Interface responsiva testada em viewport móvel de 390 x 844 px.

Conclusão

Os testes executados demonstram o funcionamento dos mecanismos principais solicitados para segurança e estabilidade da aplicação: senhas armazenadas com BCrypt, autenticação, diferenciação de perfis, autorização no servidor, consulta de dados, validação de entrada e interface responsiva. A tentativa de operação administrativa pelo perfil comum foi corretamente bloqueada com HTTP 403.

No teste de SQL Injection, a entrada não foi interpretada como comando SQL e a tabela permaneceu íntegra. Como melhoria adicional de robustez, recomenda-se também aplicar validação/sanitização de regras de negócio no servidor para rejeitar nomes ou conteúdos inadequados, mesmo quando consultas parametrizadas já impedem a execução de SQL injetado.

Resultado geral: 10 casos de teste executados, com evidências registradas.